Validating AI coding assistants under ISO 13485

A two-page guide for QA/RA leads · AI Coding Tool Validation Kit v0.1.0 · Bernardo Plaza

Five minutes of reading. The details are in the rendered package and in docs/.

Why now

- **The rules are in force.** The FDA QMSR has applied since 2 February 2026 and incorporates ISO 13485:2016, including §4.1.6: validate QMS software before initial use and after changes, proportionate to risk, with records. FDA's Computer Software Assurance guidance (revised February 2026) describes how to do it lean.
- **The tools now act.** Agents edit files, run commands, open pull requests and run in CI or in the vendor's cloud. Some products now start in autonomous modes by default. On GitHub, an AI review approval can be configured to count toward merge requirements.
- **Regulators look at oversight, not at the model.** In April 2026 FDA cited a firm whose AI agents had written GMP documents that no quality unit reviewed. FDA did not prohibit AI. It required the human review and approval that was missing.
- **Models change monthly, tools daily.** Without a change protocol, a validation is stale within weeks. The kit pins the validated client versions and raises them with an automated regression run, so developers are not frozen on old versions.

What to validate and what not

Validate the **intended use** (who, which tool and surface, for what, where, who approves), the **guardrails** (approval gates, required checks, permissions, sandbox, managed configuration, accounts, attribution) and the **verification of output** (human review plus CI on every AI-assisted change).

Do not try to qualify the LLM or test whether its code is "good": review and CI do that, and they are what you validate. The exception is when AI output itself counts as a control or as evidence, for example an AI reviewer counted as verification, or records drafted without independent checks. Then the model is pinned and tested before every change.

The unit of validation is **tool + vendor + surface + context of use**. The binding controls sit on the code host and in CI, not in the agent's local settings.

The 10 tests that matter

1. **IQ-03** The configuration baseline is captured by script and hashed.
2. **OQ-01** Real AI-assisted PRs (at least 3 per repository, at least 2 repositories) were merged only after a qualified human approval.
3. **OQ-02** A canary PR cannot be merged without approval.
4. **OQ-03 / OQ-06** A direct push to the protected branch is blocked, and an admin bypass is prevented or logged and reviewed.
5. **OQ-04** Approvals by AI, bots or CI tokens do not count, and AI identities cannot merge.
6. **OQ-05** The author, or the person who launched the agent, cannot satisfy the approval.
7. **OQ-07** Required checks block a failing test, an unapproved dependency and a secret.
8. **OQ-08 / OQ-09** Local guardrails hold (denied command, write outside the workspace, network), and users cannot override managed settings.
9. **MA-01** The fixed admission suite passes for every model in the envelope.
10. **PQ-01** In use after release for at least 4 weeks or 20 AI-assisted PRs: every merge had a qualified human approval, no bypass occurred, and every model seen was inside the envelope.

Add OQ-20 (source-citation probes) when AI drafts controlled documents, OQ-30 (oracle-based verification) for autonomous QMS agents, and OQ-40 (prompt injection) when agents read untrusted content. A gate that has never been seen to refuse something has not been tested.

Minimum record set

Record	Kit document
Inventory entry, intended use, contexts, QMS relevance, GAMP category	01
Control objectives (REQ-01 to REQ-17)	02

Record	Kit document
AI failure modes, controls, criticality and test depth	03
Plan and protocol, approved **before** execution	04, 05
Configuration baseline with file hashes	06
Evidence exports (JSON, SHA-256, UTC timestamps)	`evidence/`
Report with release decision, signed by the people themselves	07
Change triggers, admission records, periodic review	08
Work instruction and training records (ISO 13485 §6.2)	00-shared
Tool discovery reconciliation	00-shared

Keep records for at least the device lifetime and not less than two years from release (ISO 13485 §4.2.5). In the EU, records that support the technical documentation follow the MDR period: at least 10 years after the last device is placed on the market, 15 for implantables. Code-host logs expire much sooner, so export them.

Models change: how to stay validated

Treat models as a **predetermined change protocol** that you write into the validation plan before the first test:

1. **Initial validation**, once per tool and vendor: full IQ/OQ/PQ of the guardrails, plus MA-01 on every model in the initial envelope. This also fixes the suite version and its acceptance criteria.
2. **Model admission**, per new model id that matches a pre-authorised pattern written into the plan (never an alias the vendor can repoint): rerun MA-01. Guardrail criteria must pass in every run; functional criteria must pass in at least 2 of 3 runs. Pass: admit the model with a short record and add the exact id to the enforced allow-list. Fail: do not admit it, and raise a deviation if it was already in use.
3. **Re-baseline**: a new model family adds a targeted OQ subset; a new vendor or tool needs a new initial validation.

Under the default **envelope** policy any admitted model may be used, because output is verified downstream. Under the **pinned** policy (AI output used as a control or as evidence) one exact model id is allowed, and any change needs an OQ subset plus MA-01 before use.

When to revalidate

- New model or model version: MA-01 (envelope), or OQ subset plus MA-01 (pinned).
- Tool release that touches guardrails (permissions, sandbox, hooks, defaults), new surface, new context of use, or configuration change: targeted OQ subset.
- Vendor terms change (retention, training, residency): IQ-05 and a supplier review.
- Code-host rule change, incident or deviation: the gate regression tests.
- New vendor or tool: initial validation.
- Periodic review every 12 months (6 for high-risk contexts), including tool discovery.

What the kit checks

See the table "What the kit checks" in the README. For a public example of what regulators look for, see the FDA warning letter of April 2026 summarised in docs/regulatory-mapping.md (section "Signals, not requirements").

Next steps

1. Run `python3 kit.py init` and render your package (3 minutes).
2. Explore: run `checks/find_ai_footprint.py` and `checks/check_github_gates.py` on your main repositories with `--out evidence/_exploratory/`. Exploratory runs only inform the plan; they are not test evidence, and IQ-03, OQ-01 and MA-01 are re-run after the plan and protocol are approved. For a tool already in use, file the interim-control check under `evidence/<TOOL>/INTERIM/`.
3. Agree the contexts of use and the model policy with engineering, then approve the plan and protocol.
4. Execute IQ, OQ and MA-01 in about a week. Release with the PQ condition, run PQ-01 and PQ-02 for at least 4 weeks after release, and sign the addendum.
5. Put vendor release monitoring and the periodic review in your calendar.